BÙI TRƯỜNG AN

Penetration Tester / Security Engineer

Hanoi, Vietnam | 0397677835 | anbt.personal@gmail.com | merlinthemage.me | github.com/Ann-BT

SUMMARY

Cybersecurity graduate from USTH (Very Good) with a web application security background. Found and reported vulnerabilities in a web application with fixes the developers could apply, and built SIDERIS, a web attack detection and mitigation system. Hands-on with Burp Suite, OWASP ZAP and Wireshark. Looking for a Penetration Tester role in product security testing.

EXPERIENCE

Security & Software Engineer 2026

Confidential (document processing and LLM translation web app)

Self-directed security review of a production web application. Reported backend findings with remediation guidance to the backend developers and implemented the frontend fixes myself.

- Identified broken access control and reported fixes: IDOR at the database query layer, Mass Assignment prevented with strict Pydantic schemas.
- Identified file-processing flaws (XXE, Zip Slip, Zip Bomb DoS) and recommended fixes: `defusedxml`, Magic Byte validation, dynamic timeouts.
- Identified SSRF in the ONLYOFFICE integration and recommended HMAC-signed JWTs.
- Identified infrastructure risks and reported remediation: DB, Redis, and vLLM ports exposed (fix: isolated Docker networks), Pickle deserialization RCE risk in Celery, prompt injection in the LLM translation flow.
- Implemented frontend security myself: HttpOnly/SameSite cookies, CSP headers, route guards, cache cleanup on logout, to reduce XSS-based session theft.
- Supported a Level 3 information system security project.

Cybersecurity Intern 2026

ICTLab, USTH

Built SIDERIS, a sidecar web attack detection and mitigation system (Node.js/Express, React, PostgreSQL, Redis, Docker).

- Reverse-proxy deployment requiring zero changes to the protected application's source code.
- Two-layer detection: inline signature matching at the reverse proxy blocks known injection payloads, while a behavioral layer scores sessions from client telemetry and server-side rules to catch bots, brute force, scanning, and DoS.
- Risk-scored escalating response (rate limit, CAPTCHA, soft block, hard block with SOC review), enforced atomically in Redis.
- Validated with 7 attack and behavior scenarios against OWASP Juice Shop, including SQL injection, brute force, and bot form fill.
- React dashboard giving non-technical site owners a SOC-style view of threats.

SECURITY PROJECTS AND LABS

- **Phish Shield (team lead):** browser extension combining whitelist/blacklist with a Random Forest model to detect phishing URLs.
- **IDS/IPS coursework:** set up a VM, scanned and reproduced CVE-1999-0497 (anonymous FTP), configured a firewall to mitigate.
- **Offensive labs (guided):** Chronos (VulnHub) and OWASP Top 10 labs: access control bypass, OS command injection, sudo privilege escalation.
- **SMS OTP 2FA system:** Python Flask, Redis, Twilio.

COURSES

- Digital forensics (EC-Council CHFI curriculum): acquisition, anti-forensics, Windows/Linux and network forensics.
- Malware analysis: analyzed basic samples on REMnux, wrote reports.

SKILLS

- **Security tools:** Burp Suite, OWASP ZAP, Wireshark, Wazuh, IDA Pro, Process Monitor, PEStudio
- **Knowledge:** OWASP Top 10, web/API security, secure code remediation, malware analysis fundamentals, digital forensics
- **Systems/Networking:** Linux (daily user), Windows, VMs; TCP/IP, HTTP/HTTPS, DNS
- **Programming:** JavaScript/TypeScript, Node.js, Python (basic)
- **Infrastructure:** Docker, Redis, PostgreSQL, Git
- **Languages:** English (B2, USTH certified), French (A2, TCF)

EDUCATION

University of Science and Technology of Hanoi (USTH)
B.Sc. Cyber Security, Very Good. Top 3 in first year, 3-year scholarship.

CERTIFICATIONS

- Google Cybersecurity Professional Certificate
- Fortinet Certified Associate in Cybersecurity
- Cisco Network Defense